

UNIVERSITY OF DHAKA

DataLex: Explainable SIEM Security Intelligence Using Generative AI

Submitted by

Arpita Paul

Exam Roll: 303

Registration No: H-7

Abu Syeed Sajid Ahmed

Exam Roll: 325

Registration No: H-26

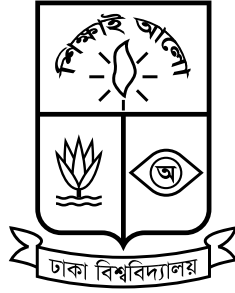
Submitted to the

Department of Computer Science and Engineering

University of Dhaka, Bangladesh

in partial fulfillment of the requirements for the degree of
Professional Masters in Information and Cyber Security (PMICS).

Declaration Form



University of Dhaka

We hereby declare that the work in this report titled “**RedGrid: Dependency-Constrained UCB Exploration for Autonomous Penetration Testing**” has been carried out by us under the supervision of Dr. Md. Abdur Razzaque. We further declare that where information has been derived from the literature, we have adequately cited and referenced the original sources. No part of this report was previously presented for another degree or diploma at this or any other institution.

Name of the Candidate

Nishan Paul

Name of the Candidate

Md Rakibur Rahman

Dr. Md. Abdur Razzaque

Professor and Chairman

Dept. of

Computer Science and Engg.

University of Dhaka

“To conquer fear, you must become fear.”

Ra’s al Ghul, Batman Begins

UNIVERSITY OF DHAKA

Abstract

Large Language Model (LLM) agents have repeatedly demonstrated the ability to exploit real-world software vulnerabilities, yet a systematic reading of the recent literature reveals two unresolved and independent failure modes. First, on the hardest realistic web benchmark (CVE-Bench), the best reported agent exploits only 13% of one-day and 10% of zero-day vulnerabilities, with *insufficient exploration* identified as the dominant cause of failure across every evaluated system. Second, on a stage-decomposed diagnostic benchmark (PentestEval), *Attack Decision-Making* – reasoning about which prerequisite weaknesses must be resolved before a candidate attack becomes feasible – is the single lowest-scoring stage of the pentesting pipeline. No system surveyed in the 29-paper corpus underlying this work addresses both failure modes at once: systems that solve exploration breadth dispatch flat, undifferentiated task lists with no explicit model of prerequisite structure, while systems that reason about dependencies do so only over small, pre-curated, expert-annotated weakness sets that cannot scale to open-ended discovery.

This report proposes **RedGrid**, a four-layer autonomous penetration-testing architecture whose central contribution is a dynamically constructed **Vulnerability Dependency Graph (VDG)** – a scored directed acyclic graph in which nodes represent candidate attack hypotheses and edges represent LLM-inferred prerequisite/enables relationships grown incrementally from live Specialist discovery. Node selection is governed by a modified Upper Confidence Bound (UCB1) formula restricted to a dependency-constrained eligible frontier, combined with path-level impact scoring so that a chain of moderate-value steps culminating in a high-impact outcome can outrank a single high-value but terminal node, and an ordinal evidence-confidence scale ($E_{\text{ord}} \in \{0, \dots, 5\}$) that replaces uncalibrated raw LLM confidence in the scoring formula. The VDG sits inside a **Dual-Layer World Model** that

strictly separates confirmed environmental facts, written exclusively by six surface-specific Specialists (Reconnaissance, SQL Injection, Cross-Site Scripting, GraphQL, Authentication/Session, and Lateral Movement), from inferred attack hypotheses, written exclusively by a Team Manager – eliminating fact/hypothesis conflation and making discovery quality independently ablatable from planning quality. Supporting infrastructure includes a four-tier memory system (vulnerability-pattern, conditional-branching strategy, technical-action, and episodic-failure memory) with oracle-gated skill promotion and an explicit negative-transfer guard, a bounded Diagnosis-Adapt-Cap validation loop, and a context-reconstruction mechanism (FullCompact) that addresses the long-session context inflation documented in prior single-agent systems.

Following the scoping discipline established in the architecture, RedGrid claims exactly three contributions, each bounded by a precisely specified experimental test: **C1** – dependency-aware attack-graph exploration, validated by demonstrating that the unified VDG outperforms a stacked (filter-after-scoring) baseline on CVE-Bench and PentestEval; **C2** – cross-mission memory with verified skill promotion, validated by measurable improvement on a seen-technology benchmark subset; and **C3** – the first standardized cross-benchmark evaluation of a single autonomous VAPT architecture across web (CVE-Bench), GraphQL (PrediQL), and multi-host (Incalmo MHBench) attack surfaces under one shared orchestration layer with surface-specific Specialist pools and strictly separated per-surface reporting. This report presents the complete system architecture, the formalized VDG algorithm, the seven-tier benchmarking strategy, the required ablation design (with McNemar’s test and 95% Wilson confidence intervals), a mandatory pre-evaluation gate on VDG edge-inference precision, and an honest accounting of the threats to validity – including the expected gap between sandboxed and real-world pass rates – that will govern the empirical evaluation to follow.

Acknowledgements

We would like to thank ...

Contents

Declaration Form	i
Abstract	iii
Acknowledgements	v
List of Figures	viii
List of Tables	ix
1 Introduction	1
1.1 Project Domain	1
1.2 Work Domain	1
1.3 Problem Statement	1
1.4 Motivation	1
1.5 Research Objectives	1
1.6 Conceptual Framework	1
1.7 Key Contributions	1
1.8 Thesis Organization	1
2 Related Works	2
2.1 Related Concepts	2
2.2 Comparative Discussions	2
2.3 Experimental Observations	2
2.4 Limitations And Research Gaps	2
3 Proposed Methodologies	3
3.1 Overview	3
3.2 System Model And Assumptions	3
3.3 Proposed Method	3
3.4 Conclusion	3
4 Performance Evaluation	4
4.1 Simulation Or Testbed Environment	4
4.2 Performance Metrics	4
4.3 Results Analysis	4

4.4 Conclusion	4
5 Conclusions	5
5.1 Summary Of Work	5
5.2 Future Direction	5
 Bibliography	 6

List of Figures

List of Tables

Chapter 1

Introduction

1.1 Project Domain

1.2 Work Domain

1.3 Problem Statement

1.4 Motivation

1.5 Research Objectives

1.6 Conceptual Framework

1.7 Key Contributions

1.8 Thesis Organization

Chapter 2

Related Works

2.1 Related Concepts

2.2 Comparative Discussions

2.3 Experimental Observations

2.4 Limitations And Research Gaps

Chapter 3

Proposed Methodologies

3.1 Overview

3.2 System Model And Assumptions

3.3 Proposed Method

3.4 Conclusion

Chapter 4

Performance Evaluation

4.1 Simulation Or Testbed Environment

4.2 Performance Metrics

4.3 Results Analysis

4.4 Conclusion

Chapter 5

Conclusions

5.1 Summary Of Work

5.2 Future Direction

Bibliography